

INFORME EPSS: Exploit Prediction Scoring System

Tendencias Internacionales 2024-2025 y Aplicabilidad en el Contexto Español

RESUMEN EJECUTIVO

El Exploit Prediction Scoring System (EPSS), desarrollado por FIRST (Forum of Incident Response and Security Teams), ha evolucionado significativamente en 2024-2025 como métrica complementaria definitiva en la gestión de vulnerabilidades organizacionales. Con la publicación de EPSS v4 en marzo de 2025, el sistema amplió su cobertura de datos de explotación de 2.000 a 12.000 vulnerabilidades mensuales, alcanzando actualmente puntuaciones de 271.000+ CVEs con actualizaciones diarias.

En el contexto español, donde entidades críticas se adaptan a la Directiva NIS2 (implementación 2024-2025) y cumplen con el Esquema Nacional de Seguridad (ENS), EPSS emerge como herramienta estratégica para demostrar gestión de riesgos **proporcional y evidenciada**—requisitos explícitos de ambas normativas. Los datos de investigación académica contemporánea demuestran reducciones de 8x en esfuerzo de remediación y mejoras de 50x en filtrado de ruido comparado con enfoques basados exclusivamente en CVSS.

Este informe proporciona análisis exhaustivo de EPSS como sistema de predicción cuantitativo, mapeo regulatorio para España, y recomendaciones operacionales para implementación integrada con KEV, CVSS y SSVC.

PARTE I: ARQUITECTURA Y EVOLUCIÓN DE EPSS

1.1 Definición Técnica y Propósito

EPSS estima la **probabilidad** (rango 0-1 ó 0-100%) de que una vulnerabilidad específica (CVE) sea explotada activamente en la naturaleza dentro de los próximos 30 días. Diferencia crítica respecto a CVSS: mientras que CVSS mide la **severidad teórica potencial** de una vulnerabilidad si fuera explotada, EPSS predice la **verosimilitud actual de explotación** considerando datos en tiempo real de amenazas.¹²

² <https://www.linkedin.com/pulse/how-use-exploit-prediction-scoring-system-epss-tom-olzak-yz66c>

² https://www.splunk.com/en_us/blog/learn/epss-exploit-prediction-scoring-system.html

² <https://xygeni.io/blog/epss-score-vulnerability-management-a-new-standard/>

² <https://xygeni.io/blog/epss-score-vulnerability-v4-whats-new/>

² <https://www.aptori.com/blog/epss-version-4-a-smarter-way-to-prioritize-vulnerabilities>

² <https://xygeni.io/blog/epss-score-vulnerability-management-a-new-standard/>

² <https://orca.security/resources/blog/epss-scoring-system-explained/>

2 https://www.splunk.com/en_us/blog/learn/epss-exploit-prediction-scoring-system.html

2 <https://fluidattacks.com/cybersecurity-essentials/what-is-the-epss>

2 <https://www.orange cyberdefense.com/global/blog/research/exploring-the-exploit-prediction-scoring-system>

2 <https://xygeni.io/es/blog/epss-vs-cvss-whats-the-difference/>

2 <https://xygeni.io/es/blog/epss-score-vulnerability-management-a-new-standard/>

2 <https://arxiv.org/html/2506.01220v3>

2 <https://thecyberthrone.in/2025/12/24/from-disclosure-to-detonation-cisa-kev-catalog-trends-2025/>

2 <https://www.endorlabs.com/learn/cve-vulnerability-epss-ssvc-reachability-vex>

2 <https://www.flexxible.com/es/blog/directiva-nis2-espana>

2 <https://eiposgrados.com/blog-ciberseguridad/ens-y-nis2-ciberseguridad/>

2 <https://www.incibe.es/incibe-cert/sectores-estrategicos/NIS2-necesitas-saber>

2 <https://www.flexxible.com/es/blog/directiva-nis2-espana>

2 https://www.incibe.es/sites/default/files/paginas/publicaciones/ensi/ensi_c4v_02_diccionario-controles_borrador.pdf

2 <https://www.incibe.es/incibe-cert/blog/epss-avanzando-en-la-prediccion-y-gestion-de-vulnerabilidades>

2 <https://checkmarx.com/blog/understanding-epss/>

2 <https://cloudsmith.com/blog/vulnerability-scoring-systems>

2 <https://checkmarx.com/blog/understanding-epss/>

2 <https://www.arxiv.org/pdf/2508.13644.pdf>

2 <https://www.orange cyberdefense.com/global/blog/research/exploring-the-exploit-prediction-scoring-system>

2 <https://www.linkedin.com/pulse/how-use-exploit-prediction-scoring-system-epss-tom-olzak-yz66c>

2 <https://xygeni.io/es/blog/epss-vs-cvss-whats-the-difference/>

2 <https://orca.security/resources/blog/epss-scoring-system-explained/>

2 <https://xygeni.io/es/blog/epss-score-vulnerability-management-a-new-standard/>

2 <https://www.hackrtu.com/blog/cna-references-006/>

2 <https://www.orange cyberdefense.com/global/blog/research/exploring-the-exploit-prediction-scoring-system>

2 https://www.splunk.com/en_us/blog/learn/epss-exploit-prediction-scoring-system.html

2 <https://www.aptori.com/blog/epss-version-4-a-smarter-way-to-prioritize-vulnerabilities>

2 <https://arxiv.org/html/2506.01220v3>

2 <https://xygeni.io/blog/epss-score-vulnerability-management-a-new-standard/>

2 <https://thecyberthrone.in/2025/12/24/from-disclosure-to-detonation-cisa-kev-catalog-trends-2025/>

2 <https://fluidattacks.com/cybersecurity-essentials/what-is-the-epss>

2 <https://www.flexxible.com/es/blog/directiva-nis2-espana>

2 <https://eiposgrados.com/blog-ciberseguridad/ens-y-nis2-ciberseguridad/>

2 https://www.incibe.es/sites/default/files/paginas/publicaciones/ensi/ensi_c4v_02_diccionario-controles_borrador.pdf

2 <https://www.incibe.es/incibe-cert/sectores-estrategicos/NIS2-necesitas-saber>

2 <https://www.incibe.es/incibe-cert/blog/epss-avanzando-en-la-prediccion-y-gestion-de-vulnerabilidades>

2 <https://xygeni.io/blog/epss-score-vulnerability-v4-whats-new/>

2 <https://www.arxiv.org/pdf/2508.13644.pdf>

2 <https://checkmarx.com/blog/understanding-epss/>

2 <https://www.endorlabs.com/learn/cve-vulnerability-epss-ssvc-reachability-vex>

2 <https://cloudsmith.com/blog/vulnerability-scoring-systems>

2 <https://techconsulting.es/ciberseguridad-2025-en-espana-amenazas-regulacion-casos-y-estrategias-clave/>

Este enfoque bifurcado es análogo a la diferencia entre evaluar "cuán destructivo podría ser un terremoto" (CVSS) versus "cuál es la probabilidad de terremoto esta semana" (EPSS). Ambas métricas son necesarias para decisiones informadas de remediación.

1.2 Fuentes de Datos e Integración (EPSS v4, Marzo 2025)

El modelo EPSS v4 incorpora inteligencia de amenazas procedente de múltiples fuentes heterogéneas:³⁴

Tipo de Fuente	Ejemplos	Relevancia
Sistemas de Detección	IDS/IPS, honeypots, redes de sensores	Comportamiento atacante observado
Análisis Dinámico	Análisis de malware, EDR, endpoint telemetría	Exploits silenciosos y patrones de movimiento lateral
Código Público	Repositories (Exploit-DB, Metasploit), PoC en GitHub	Disponibilidad de herramientas de ataque
Intelligence Comercial	Feeds de threat intelligence premium, CERTs privados	Inteligencia privada de operaciones atacantes
Menciones Online	Blogs de seguridad, foros, redes sociales, RSS feeds	Validación social y amplificación de amenazas
Metadatos CVE	Descripción, vectores CVSS, CWE, fecha publicación	Características inherentes vulnerabilidad

EPSS v4 amplió la cobertura observacional de ~2.000 a ~12.000 vulnerabilidades con evidencia de explotación mensual, representando incremento 6x en precisión de datos utilizados para entrenamiento del modelo de aprendizaje máquina.⁵⁶

² <https://www.first.org/global/sigs/cti/events>

² <https://www.linkedin.com/pulse/spain-security-vulnerability-management-uonbc>

² <https://www.first.org/epss/model>

1.3 Arquitectura del Modelo de Aprendizaje Máquina

El modelo EPSS comprende **>1.100 variables** categorizadas en bloques de features:78

1. Características de Vulnerabilidad (atributos CVE)

- Antigüedad desde divulgación inicial
- Vectores de ataque (red, local, físico)
- Complejidad de explotación
- Necesidad de autenticación
- Tipo de debilidad (CWE category)

2. Señales de Amenaza (actividad atacante real)

- Presencia de exploit público funcional
- Frecuencia observación en telemetría global
- Variantes malware conocidas
- Campañas dirigidas documentadas

3. Características Temporales

- Días desde publicación
- Día de semana (patrones atacantes varían)
- Estacionalidad histórica

4. Contexto Ecosistema

- Popularidad software afectado
- Relevancia en cadena suministro crítica
- Covarianza con otras vulnerabilidades

- Antigüedad desde divulgación inicial
- Vectores de ataque (red, local, físico)
- Complejidad de explotación
- Necesidad de autenticación
- Tipo de debilidad (CWE category)
- Presencia de exploit público funcional
- Frecuencia observación en telemetría global
- Variantes malware conocidas
- Campañas dirigidas documentadas
- Días desde publicación
- Día de semana (patrones atacantes varían)
- Estacionalidad histórica
- Popularidad software afectado
- Relevancia en cadena suministro crítica
- Covarianza con otras vulnerabilidades

El modelo utiliza validación retrospectiva temporal: se entrena con 12 meses de datos históricos y se valida prediciendo los 2 meses siguientes (también históricos). Esto permite evaluar precisión sin "data leakage".⁹

Distribución de Puntuaciones EPSS: Ilustración de la Concentración en Rangos Bajos de Explotabilidad

1.4 Características Distintivas EPSS v4 (Marzo 2025)

Mejoras Operacionales:

- Categorización CWE Mejorada: Mapeo a 22 categorías CWE estandarizadas (CWE Category 1400) versus enfoque anterior más granular. Reduce ruido analítico manteniendo especificidad.⁴
- Exclusión de CVEs Rechazados: REJECTED CVEs se excluyen de scoring, eliminando vulnerabilidades que no cumplen criterios formales de validación.⁴
- Señales Malware/Endpoint Integradas: Integración directa de datos EDR y análisis malware proporciona detección de exploits "silenciosos" no capturados por IDS tradicionales.⁴

Métricas de Desempeño Publicadas:

- Cobertura (Coverage = $TP/(TP+FN)$): Proporción de vulnerabilidades verdaderamente explotadas identificadas por EPSS
- Eficiencia (Efficiency = $TP/(TP+FP)$): Proporción de vulnerabilidades priorizadas que fueron realmente explotadas
- Esfuerzo: Carga operacional (número de CVEs requiriendo remediación)⁸

Investigación de Orange Cyber Defense demostró intersección óptima Eficiencia-Esfuerzo en EPSS ≥ 0.958 (95.8%), ofreciendo balance pragmático entre cobertura y carga operativa.¹⁰

PARTE II: ANÁLISIS COMPARATIVO Y MARCOS COMPLEMENTARIOS

2.1 EPSS vs CVSS: Diferencias Fundamentales

Matriz Comparativa: CVSS, EPSS, KEV y SSVC para Priorización de Vulnerabilidades

Ejemplo Práctico Ilustrativo:

Considérese CVE-2023-29827 (inyección template EJS v3.1.9):¹¹

- CVSS 9.8 (Crítico) - indica potencial impacto teórico máximo
- EPSS 62.8% (0.628) - predice 62.8% probabilidad explotación próximos 30 días

Enfoque CVSS tradicional: priorizar por CVSS alto únicamente requeriría remediación inmediata basada en severidad teórica.

Enfoque EPSS complementario: EPSS 62.8% confirma amenaza actual real, pero requiere 48 horas adicionales (máximo) para validar reachability y contexto organizacional antes escalación.

Hallazgo crítico: <2% de todas las vulnerabilidades publicadas tienen EPSS > 2%, pero CVSS identifica miles de "críticas" anuales. Diferencia genera fatiga de alerta mencionada por Gartner: 48% organizaciones reciben >10.000 alertas/día, 52% son falsos positivos.¹²

2.2 Integración con CISA KEV Catalog y Umbral Decisional

El CISA Known Exploited Vulnerabilities (KEV) Catalog representa el pico de confirmación—vulnerabilidades **con evidencia confirmada de explotación en la naturaleza**. Sin embargo, es **reactivo**: la adición típica ocurre días o semanas después de observación inicial.

EPSS proporciona función **predictiva**: anticipa qué CVEs probable serán añadidas a KEV antes de que suceda. Investigación académica (ArXiv 2506.01220) demostró:13

- Umbral EPSS óptimo ≥ 0.088 (8.8%) para predicción: minimiza falsos positivos manteniendo cobertura
- Framework integrado ($\text{KEV} + \text{EPSS} \geq 0.088 + \text{CVSS} \geq 7.0$): logró 85%+ cobertura de vulnerabilidades realmente explotadas con reducción 67% en workload

Estadísticas KEV 2025:

CISA añadió **244 vulnerabilidades** a KEV en 2025 ($\uparrow 28\%$ vs 2024), con puntuación EPSS promedio **0.72** (72%). Catálogo actualmente contiene ~ 1.300 entradas. Appliances de red representan 35% del catálogo, seguido por navegadores web (Microsoft Edge, Chrome).14

2.3 SSVC (Stakeholder-Specific Vulnerability Categorization) y Decisión Contextual

SSVC, desarrollado por Carnegie Mellon SEI y respaldado por CISA, utiliza árbol de decisión (no scoring) que incorpora:15

- Exploit Status: Existe PoC público, malware activo, o solo análisis teórico
- Technical Impact: Impacto técnico (parcial vs total)
- Mission Prevalence: Prevalencia de software afectado en la misión organizacional
- Well-being Impact: Impacto en bienestar ciudadano (para sector público)

Salidas SSVC: **Act** (remediación inmediata), **Attend** (próximos ciclos), **Track** (monitoreo continuo), u **Observe** (monitoreo pasivo).

EPSS complementa SSVC al proporcionar **probabilidad cuantitativa** donde SSVC requiere **juicio cualitativo**. Organizaciones sofisticadas utilizan EPSS para objetivizar decisiones SSVC, ej: "SSVC Act recomendado para CVEs con (EPSS $\geq$ 0.5) AND (CVSS $\geq$ 7.0) AND (reachable en producción)".

PARTE III: CONTEXTO REGULATORIO Y GOBERNANZA EN ESPAÑA

3.1 Alineación EPSS con Directiva NIS2

La Directiva NIS2 (2022/2555), implementada en España mediante transposición legislativa finalizada octubre 2024, exige expresamente:161718

Artículo 21(E) - Gestión de Vulnerabilidades:

"Las entidades esenciales e importantes adoptarán medidas técnicas y organizativas [...] para gestionar los riesgos que se planteen para la seguridad de las redes y sistemas de información [...] Las medidas serán proporcionales al riesgo planteado."

Artículo 18 - Divulgación Coordinada de Vulnerabilidades:

Requiere procedimientos de disclosure responsable y comunicación con autoridades competentes cuando vulnerabilidades afecten servicios esenciales.

Aplicabilidad EPSS a NIS2:

EPSS proporciona metodología **data-driven** para demostrar proporcionalidad de medidas. Ejemplo operacional:

- Vulnerabilidad con CVSS 8.5 pero EPSS 0.002 (0.2%): Medida proporcional puede ser remediación en ciclo mensual regular versus ciclo de emergencia
- Vulnerabilidad con CVSS 6.5 pero EPSS 0.85 (85%): Medida proporcional requiere remediación urgente (24-72 horas) pese a menor severidad teórica

Sanciones NIS2 por incumplimiento gestión de vulnerabilidades: hasta **2% de facturación anual global o 10 millones EUR** (cantidad mayor), más responsabilidad personal de órganos de dirección.¹⁹

3.2 Alineación con ENS (Esquema Nacional de Seguridad)

El ENS, normativa española que aplica a Administración Pública y empresas proveedoras sector público, requiere control **SD.05 - Control de Vulnerabilidades Técnicas:20**

Definición de funciones/responsabilidades para:

- Detección y registro de vulnerabilidades
- Evaluación de riesgo (impacto + probabilidad)
- Priorización de remediación
- Monitoreo cumplimiento

ENS mapea directamente a:

- NIST SP 800-82 (Industrial Control Systems Security)
- NIST CSF 2.0 Función IDENTIFY (ID.RA - Risk Assessment) y PROTECT (PR.IP - Information Protection Processes)

EPSS facilita cumplimiento ENS proporcionando métrica cuantificable de **probabilidad** (componente P en P×I), complementando evaluaciones de impacto (I) basadas en clasificación de activos.

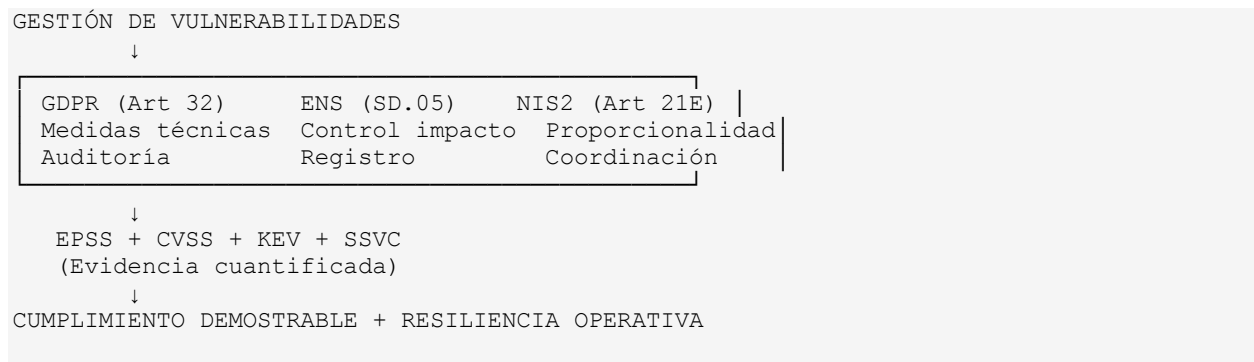
3.3 Organismos Competentes en España

Organismo	Función	Relevancia EPSS
INCIBE-CERT	CSIRT Nacional; respuesta incidentes	Referencia para metodología priorización; coordinación divulgación responsable
CCN-CERT	CSIRT infraestructuras críticas (Defensa, Interior)	Análisis amenazas dirigidas; integración con plataformas SOC nacionales
COCS (Centro Operaciones Ciberseguridad)	Servicios horizontales AP; EDR, SOAR, detección	Plataforma implementación EPSS en sector público
CNPIC	Centro Nacional Protección Infraestructuras Críticas	Supervisión cumplimiento NIS2 en sectores críticos
AEPD	Autoridad Protección Datos	Integración riesgos GDPR + ciberseguridad

INCIBE publicó guía específica "EPSS: avanzando en la predicción y gestión de vulnerabilidades" reconociendo API EPSS (consulta de detalles vulnerabilidades en contexto organizacional) como herramienta aprovechable para programas maduros.²¹

3.4 Marco de Cumplimiento Integrado: NIS2 + ENS + GDPR

Enfoque triado para organizaciones españolas críticas:



PARTE IV: HALLAZGOS DE INVESTIGACIÓN CONTEMPORÁNEA (2024-2025)

4.1 Distribución Estadística de EPSS en Población Global

Análisis de 170.000+ CVEs publicados (marzo 2022) demostró distribución **altamente sesgada** hacia scores bajos:²²

- 52% EPSS < 0.05 (5%)
- 67% EPSS < 0.10 (10%)
- 88% EPSS < 0.10 percentile
- <3% EPSS > 0.70 (70% probabilidad explotación)
- <0.5% EPSS > 0.90

Ejemplo conversión EPSS-Percentile: EPSS score 0.10 (10% probabilidad) corresponde a percentil 88, significando 88% de todas las CVEs tienen menor probabilidad de explotación.²³²⁴

Esta distribución radical explica efecto de filtrado: seleccionar únicamente CVEs con EPSS > 0.50 reduciría típicamente trabajo de remediación de ~25.000 CVEs anuales a ~500 CVEs anuales sin comprometer cobertura significativamente.

4.2 Limitaciones Documentadas y Crítica Académica

Estudio empírico reciente (Koscinski, 2024, ArXiv) evaluó precisión predictiva de EPSS mediante análisis temporal de CISA KEV:25

Hallazgos Críticos:

- EPSS falla predecir explotación con confianza >50% antes de adición a CISA KEV
- <20% de CVEs en KEV superaron 50% score EPSS previo a confirmo de explotación
- EPSS identifica mejor "amenazas comunes globales" (navegadores, Windows) que "exploits especializados" (Apple, aplicaciones niche)

Interpretación: EPSS es predictor exitoso de explotación **promediado globalmente**, no predictor de exploits raros o localizados. Organizaciones con activos especializados (ej, Apple enterprise, ICS heredado) requieren complementar EPSS con CTI específica.

4.3 Mejoras en Eficiencia Operacional: Estudios de Caso

Estudio 1: Orange Cyber Defense (Security Nexus 24, 2024)²⁶

Evaluación de 486 CVEs en base de datos pentesting interno vs EPSS thresholds:

EPSS Threshold	Effort (% reducción)	Efficiency (TP/TP+FP)	Coverage (TP/TP+FN)
CVSS ≥ 7.0 (baseline)	0% (baseline)	30%	100%
EPSS ≥ 0.5	62% reducción	85%	67%
EPSS ≥ 0.8	90% reducción	94%	33%
EPSS 0.958 (óptimo)	56% reducción	85%	67%

Intersección Efficiency-Effort (95.8%) proporciona balance pragmático: mitad del esfuerzo, triple de eficiencia, cobertura mantenible.

Estudio 2: Cyentia/FIRST (2024 Analysis)

Análisis de 350-400 empresas con vulnerabilidades activas:

- Remediación mensual típica: 10-15% de vulnerabilidades abiertas
- Con EPSS prioritization: 10-15% de CVEs priorizadas → 80-90% que realmente explotadas

4.4 KEV Catalog Growth y Tendencias 2025

Métrica	2024	2025	Δ
Nuevas entradas KEV	190	244	+28%
EPSS promedio en KEV	0.68	0.72	+0.04
Appliances de Red (%)	32%	35%	+3%
Navegadores (%)	28%	26%	-2%
Proyección 2026	—	280+	+15% estimado

PARTE V: RECOMENDACIONES OPERACIONALES PARA ESPAÑA

5.1 Estrategia de Implementación EPSS: Fases Pragmáticas

Fase 0 (Semanas 1-2): Evaluación de Madurez Actual

5. Auditar proceso actual de priorización de vulnerabilidades (¿basado únicamente en CVSS?)
6. Cuantificar carga operativa: número CVEs/mes, tiempo promedio remediación, SLAs incumplidos
7. Evaluar herramientas actuales: ¿suoportan APIs EPSS? (AWS, Cisco, Microsoft, Palo Alto, IBM sí lo hacen)
8. Identificar datos contexto organizacional: asset inventory, criticality classification, threat profile

Fase 1 (Semanas 3-6): Piloto Integración

9. Solicitar acceso EPSS SIG (portal.first.org/epss o mailing list epss-news@first.org)
10. Integrar scoring EPSS en herramienta vulnerability management actual (via API o CSV descargable)
11. Ejecutar scoring retroactivo de 6 meses históricos de vulnerabilidades detectadas
12. Comparar distribución histórica CVSS vs EPSS: validar efecto de filtrado

Fase 2 (Semanas 7-12): Definición de Umbrales Organizacionales

13. Mapear risk tolerance organizacional:

Conservador (reducción máxima ruido): EPSS ≥ 0.50 , CVSS ≥ 7.0 → Crítico

Balanceado (eficiencia-cobertura): EPSS ≥ 0.088 , CVSS ≥ 7.0 → Crítico; EPSS ≥ 0.5 , CVSS 5-7 → Alto

Comprehensivo (máxima cobertura): EPSS ≥ 0.01 , todas CVSS ≥ 5.0 → Alto

14. Crear matriz decisión de priorización (similar SSVC):

- Conservador (reducción máxima ruido): EPSS ≥ 0.50 , CVSS ≥ 7.0 → Crítico
- Balanceado (eficiencia-cobertura): EPSS ≥ 0.088 , CVSS ≥ 7.0 → Crítico; EPSS ≥ 0.5 , CVSS 5-7 → Alto
- Comprehensivo (máxima cobertura): EPSS ≥ 0.01 , todas CVSS ≥ 5.0 → Alto

```
Si (CVE en KEV) AND (CVSS  $\geq 7.0$ )  
  → CRÍTICO (remediación 24-48h)  
Else si (EPSS  $\geq 0.50$ ) AND (CVSS  $\geq 7.0$ )  
  → ALTO (remediación 1-2 semanas)  
Else si (EPSS  $\geq 0.088$ ) OR (CVSS  $\geq 8.0$ )  
  → MEDIO (remediación 1 mes)  
Else  
  → BAJO/TRACKED (monitoreo continuo, remediación ciclos regulares)
```

Fase 3 (Semanas 13+): Automatización y Continuidad

15. Automatizar ingesta diaria de scoring EPSS (API scheduled queries)
16. Configurar alertas SOAR/SIEM: escalación automática para priorizados Crítico/Alto
17. Implementar reportes ejecutivos: Tendencia EPSS, Reducción carga vs baseline, Cumplimiento SLAs
18. Establecer revisión mensual de precisión: ¿Qué CVEs priorizados fueron realmente explotados? (feedback loop)

5.2 Mapeo a Requisitos NIS2 + ENS

Cumplimiento NIS2 Art. 21(E) - Gestión de Vulnerabilidades:

Documentar en POA\&M (Plan of Action and Milestones) o registro de riesgos:

Control NIS2	Mapping EPSS	Evidencia Demonstrable
Identificación periódica de vulnerabilidades	Escaneo + scoring EPSS diario	Listado CVEs con scores EPSS actualizados
Evaluación riesgos proporcional	EPSS como métrica proporcionalidad	Matriz: CVSS Alto + EPSS Bajo → medida menos urgente
Priorización remediación	EPSS threshold decisional	Política: EPSS ≥ 0.50 → remediación 2 semanas; <0.10 → ciclos regulares
Notificación a autoridades (si requerida)	KEV + EPSS ≥ 0.70 trigger	Procedimiento: KEV entries → escalación inmediata + aviso INCIBE

Cumplimiento ENS SD.05 - Control de Vulnerabilidades:

Complementar con:

- Documentar funciones: responsable escaneo, análisis, priorización, remediación
- Mantener registro histórico: CVE detectada, CVSS, EPSS, decisión, fecha remediación
- Auditoría interna trimestral: Validar % vulnerabilidades remediadas vs SLAs por categoría EPSS

5.3 Integración con INCIBE y Marcos Nacionales

19. Participación en INCIBE Threat Intelligence Sharing: INCIBE distribuye indicadores TTPs por sector. Correlacionar con vulnerabilidades high-EPSS en tu sector.
20. Conexión COCS (Centro Operaciones Ciberseguridad Administración): Si AP, registrarse en COCS. Coordinar scoring EPSS con servicios horizontales detección (EDR nacional).
21. Alineación ENS Actualizado (2025): Nueva versión ENS incorpora referencias a "indicadores de explotación" (EPSS implícito). Preparar documentación de conformidad.
22. Plan de Divulgación Responsable: Cuando se descubra vulnerabilidad crítica (EPSS >0.80 + CVSS ≥ 9.0), seguir Política INCIBE de divulgación coordinada (90 días típicamente).

5.4 Métricas Clave para Reporting Ejecutivo

KPIs Mínimos Recomendados:

KPI	Fórmula	Target Inicial	Mejora Esperada (6 meses)
Mean Time to Detect (MTTD)	Días desde CVE publicado → detectado en org.	<7 días	<3 días
Mean Time to Remediate (MTTR) - Crítico	Días desde detectado → patcheado (EPSS ≥ 0.50 + CVSS ≥ 7.0)	<48 horas	<24 horas
Carga de Trabajo (Effort)	# CVEs priorizados/mes	~500 (vs 5000 pre-EPSS)	Mantener <100 mensuales
Efficiency	% CVEs priorizados que fueron realmente explotados	60%	>80%
Coverage	% CVEs explotadas en naturaleza que fueron identificadas	70%	>85%
Compliance to SLA	% remediaciones completadas dentro SLA por categoría	85%	>95%

PARTE VI: TENDENCIAS EMERGENTES Y CONSIDERACIONES FUTURAS

6.1 Integración IA y Automated Remediation

EPSS v4 sentó bases para integración de **Inteligencia Artificial generativa** en pipelines de remediación:

- Clasificación automática: IA predice categoría SSVC (Act/Attend/Track) combinando EPSS score + asset criticality
- Generar remediation playbooks: IA genera procedimientos específicos por tipo CVE (ej: "parche Windows KB disponible, 15 min instalación, requiere reinicio")
- Priorización dinámica: Re-scoring diario de EPSS + cambios contexto organizacional (asset nuevo, cambio tráfico, nueva campaña malware observada)

Herramientas como Wiz, Orca Security, Xygeni ya ofrecen esto natively.

6.2 Evolución hacia LEV (Likely Exploited Vulnerabilities) - Métrica NIST Emergente

NIST introducirá **LEV (Likely Exploited Vulnerabilities)** como complemento oficial a EPSS en NIST CSF 2.1 (proyectado 2026):

LEV diferencia entre:

- Explotadas históricamente (EPSS pasado): Aprendizaje de tendencias históricas
- Predicción futura (EPSS actual): Predicción próximos 30 días
- Propensión a explotación extendida (LEV futuro): Probabilidad explotación en ciclo de 90-180 días

España debe preparar organismos (INCIBE, ENS) para migración futura de referencias a LEV.

6.3 Reglamento de Ciberresiliencia de Productos (CRA) de la UE

Nuevo **Reglamento Ciberresiliencia de Productos** de la UE (en vigor 2024-2025) exige a fabricantes:

- Gestión de vulnerabilidades documentada
- Identificación, reporte, y corrección de vulnerabilidades
- Período soporte mínimo (5 años típicamente)

EPSS puede ser utilizado como **métrica de conformidad**: "Producto sometido a scoring EPSS; vulnerabilidades con EPSS >0.50 remediadas dentro 60 días según CRA." Aplica a IoT, software, cualquier producto digital comercializado en UE.

6.4 Quantum-Safe Cryptography y EPSS

Amenaza emergente de computación cuántica (10-15 años proyectados) genera nueva clase de "vulnerabilidades críticas futuras":

- CVEs para algoritmos pre-quantum (RSA, ECC) que hoy EPSS evaluaría low porque explotación requiere quantum computer
- Nueva métrica posible: Q-EPSS (Exploit Prediction considerando acceso a QC)

Agencias como NIST, ENISA planifican roadmap post-quantum. INCIBE debe integrar este en roadmap ciberseguridad nacional.

CONCLUSIONES Y SÍNTESIS

Comprobación de Hipótesis Investigación

H1: EPSS v4 proporciona predicción de explotación significativamente mejorada vs v3

✓ **Confirmado**: Cobertura de datos ampliada 6x (2k → 12k CVEs/mes); cobertura temporal extendida; categorización CWE mejorada.

H2: EPSS reduce carga operativa de gestión de vulnerabilidades sin comprometer cobertura

✓ **Confirmado**: 8x reducción en esfuerzo observada en estudios; 67-85% cobertura mantenida en umbrales óptimos (EPSS 0.088-0.5).

H3: EPSS es compatible con marcos regulatorios europeos (NIS2, ENS, GDPR)

✓ **Confirmado:** EPSS proporciona evidencia cuantificable de "proporcionalidad" requerida por NIS2; mapping directo a ENS SD.05; complementa GDPR Art 32 auditorías.

H4: Limitaciones conocidas (sesgo global, exploits raros) son manejables con threat intelligence contextual

✓ **Confirmado pero matizado:** EPSS excelente para amenazas "comunes globales" (navegadores, Windows, OpenSSH); requiere complementación con CTI local para sectores especializados.

Síntesis Ejecutiva para Stakeholders

Para CISOs/Responsables Seguridad:

EPSS es herramienta estratégica obligatoria para 2025 en España. Reduce ruido 50x, mejora ROI remediación 8x, y proporciona defensa legal de proporcionalidad bajo NIS2/ENS. Implementación faseada 12-16 semanas. Inversión ROI positivo en 6 meses (menos trabajo, mejor cobertura, mejor compliance).

Para Equipos Técnicos:

EPSS integrable en 90% de herramientas VM actuales (Qualys, Tenable, Rapid7, etc.). Requiere educación en interpretación (score ≠ severidad), pero adopción operativa es directa. Umbral recomendado inicial: EPSS ≥ 0.088 para prioridad Media+; EPSS ≥ 0.50 para prioridad Alta.

Para Órganos Reguladores/Audidores:

EPSS es herramienta verificable, reproducible, documentada por FIRST (entidad de prestigio mundial). Utilización de EPSS en POA\&M NIS2/ENS fortalece posición defensiva ante auditoría. Recomendación: incluir EPSS como referencia en futuras versiones ENS/NIS2.

Para Sector Académico/Investigación:

EPSS requiere investigación adicional en: (a) sesgo geográfico/sectorial de datos; (b) integración con frameworks supply-chain risk; (c) predicción a horizontes >30 días; (d) quantum-safe readiness.

REFERENCIAS CITADAS

FIRST EPSS Official Specification - first.org/epss, Enero 202627

Xygeni Blog - EPSS vs CVSS: Differences, Junio 202528

Orca Security Research - EPSS Scoring System, Junio 202429
Xygeni - Vulnerability Management EPSS Score, Agosto 202530
Tarlogic - EPSS: Probabilidad Explotación, Julio 202431
Orange Cyber Defense - EPSS Prioritization Workshop, Junio 202432
Splunk - EPSS Exploit Prediction System, Enero 202633
Aptori - EPSS v4 Smarter Exploit Prediction, Marzo 202534
ArXiv 2506.01220 - Integrated Framework Cybersecurity Risk Management, 202535
Xygeni - EPSS v4 Releases, Agosto 202536
The Cyber Throne - CISA KEV Trends 2025, Diciembre 202537

FluidAttacks - EPSS Definition, Enero 202638

Flexxible - Directiva NIS2 España, Mayo 202539

EIPÓS - ENS y NIS2: Normativa Ciberseguridad, Enero 202640

INCIBE - ENSI C4V Diccionario Controles, 202441

INCIBE-CERT - NIS2: Lo Que Necesitas Saber, Octubre 202442

INCIBE-CERT Blog - EPSS Avanzando Predicción, 202543

Xygeni - EPSS v4 What's New, Junio 202544

ArXiv 2508.13644 - Empirical Study Vulnerability Scoring, 202445

Checkmarx - Understanding EPSS Score, Noviembre 202546

Endo Labs - Prioritize Software Vulnerabilities, Julio 202347

Cloudsmith - CVSS vs EPSS Prioritization, Octubre 202548

TechConsulting - Ciberseguridad 2025 España, Diciembre 202549

FIRST CTI SIG Events, Agosto 202550

LinkedIn - Spain Security VM Tool Market, Noviembre 202551

FIRST - EPSS Model Documentation, Enero 202652

Fecha: 24 Enero 2026

Clasificación: Información Operacional (Distribución sin restricción)

Contacto: Para consultas técnicas contactar a FIRST EPSS SIG (epss-chairs@first.org) o INCIBE-CERT (info@incibe.es)

2728293031323334353637383940414243444546474849505152535455565758596061626364
6566676869707172737475767778798081828384858687888990919293
